

Praneesh R V

CB.SC.U4CYS23036

ISRM - Classroom Activity - Privacy Management

Information Privacy Management

Course-notes explainer covering two exam answers: (1) searchable encryption over S3 images indexed in DynamoDB, and (2) PII exposure, encryption, key custody, consent, retention, and privacy-by-design in a healthcare app.

Frame: ISM vs IPM

	Information Security Management	Information Privacy Management
Question	Can an attacker get in?	Should this data exist, for this purpose, this long?
Goal	CIA of information assets	Lawful, ethical, rights-respecting handling of personal data
Standards	ISO 27001, NIST, CIS	GDPR, CCPA, HIPAA, ISO/IEC 27701

Integrated programs pair ISO 27001 (security) with ISO 27701 (privacy extension).

PIA/DPIA triggers: sensitive personal data (health, biometric, financial); new tech (AI, biometrics, tracking, blockchain, metaverse); third-party data sharing; large-scale or systematic surveillance.

Privacy by Design: protections built into architecture from the start, not bolted on. Examples: E2E encryption in messaging, cookie defaults set to “reject all”, Osano blocking all cookies until explicit consent, Chrome Incognito, Brave (ad blocking + HTTPS + Tor private windows), Scratch collecting minimal data, LEGO Life under COPPA.

Q1 — DynamoDB as an encrypted-search index for S3 images

Split of duties

S3 holds ciphertext image blobs. DynamoDB holds the searchable index of **keyword tokens**. Neither stores plaintext; neither ever holds the search key.

Upload path (all crypto client-side)

1. Client requests a data key from AWS KMS → plaintext DK + wrapped DK.
2. Encrypt image AES-256-GCM with DK. Upload {ciphertext, wrapped DK, IV, auth tag} to S3 under a random object ID.
3. Extract keywords locally: chest-xray, patient-4471, 2026-08, pneumonia.
4. Per keyword compute token = HMAC(K_search, keyword). K_search never leaves the client.
5. Write a DynamoDB item: PK = token, SK = objectID, encrypted metadata attribute.

Search path

1. Client computes token = HMAC(K_search, "chest-xray") → 0xabc3.
2. Sends only the token. Query on PK = 0xabc3.
3. DynamoDB returns matching objectIDs — exact match on a hash partition key, O(1), no scan.
4. Client GetObject from S3, unwraps DK via KMS, decrypts locally.

The server only performs equality comparison over opaque hashes. It cannot invert the HMAC and cannot read the image.

Why DynamoDB fits

Property	Benefit
Hash partition key, exact match	HMAC token is already uniform-random → even partition spread, no hot key
No range queries needed	Encrypted equality search needs nothing more
GSI	Multiple token dimensions (tag, date bucket, owner) without reindexing
Encryption at rest via KMS	Second layer beneath the client-side tokens
IAM dynamodb:LeadingKeys	Scope a principal to only its own partition keys — tenant isolation

Property	Benefit
VPC Gateway Endpoint	Index traffic never crosses the public internet
Streams	Immutable audit trail of index reads/writes
Single-digit ms at any scale	Search latency flat as the corpus grows

Leakage and limits (the marks live here)

- **Deterministic tokens** → one keyword always maps to one token. Server learns access patterns and query frequency, and can frequency-analyse against a known keyword distribution even though HMAC is irreversible. Mitigate: per-user salt, token rotation, dummy padding entries, ORAM for stronger hiding.
- **No range / substring / fuzzy search** — HMAC destroys order. Use bucketing (date=2026-08), order-revealing encryption, or a client-side filter pass.
- **Result-set size leaks**; pad partitions to a fixed size.
- **K_search loss = permanent loss of searchability** → protect it with proactive secret sharing (share refresh over epochs so a slow compromise of one holder never accumulates enough shares).

Q2 — Healthcare app privacy

PII / PHI exposed

Class	Examples
Direct identifiers	Name, DOB, address, phone, email, Aadhaar/SSN, MRN, face photo
Health (special category)	Diagnoses, ICD codes, prescriptions, labs, imaging, allergies, HIV / mental health / reproductive
Financial	Card/UPI, bank, insurance policy number, billing history
Biometric	Fingerprint / face unlock templates
Genetic	Sequencing, family history
Behavioral / technical	Device ID, IP, GPS, appointment history, telemetry, crash logs
Third-party PII	Next of kin, emergency contact, guardian

Identifier + condition together is worse than either alone. Health data is irrevocable — a card number can be reissued, an HIV status cannot.

What should have been encrypted

- **In transit:** TLS 1.3 everywhere, cert pinning on mobile, no plaintext internal hops.
- **At rest:** AES-256 on DB, object store, **backups**, replicas, queues, search indexes, logs.
- **Field-level** above disk encryption: direct identifiers and special-category fields, so a DB dump or a rogue DBA still yields ciphertext.
- **Tokenize / pseudonymize:** clinical rows carry an opaque patient token; the token→identity map lives in a separate store under separate keys. Breach of one table is not breach of a person.
- **On device:** encrypted local cache, no PHI in notification previews, none in URLs, query strings, or analytics payloads.
- Passwords are **hashed, not encrypted** — Argon2id with per-user salt.

Keys on the same server? No.

Encryption's security model is "attacker gets ciphertext but not key." Co-locating them collapses two controls into one: a single server compromise yields both, so encryption provides **zero** marginal protection while still passing an audit checkbox. It also breaks separation of duties (ops access silently becomes key custody) and fails the "appropriate technical measures" bar in HIPAA §164.312 and GDPR Art. 32.

Correct design: KMS/HSM as a separate trust domain; envelope encryption with a master key that never leaves the HSM; a distinct IAM principal for key use; scheduled rotation; every Decrypt audited; per-tenant or per-patient data keys to bound blast radius. Key custodian ≠ data custodian. Long-lived master keys benefit from proactive secret sharing.

Consent management

- **Granular and purpose-specific** — separate toggles for treatment, billing, research, marketing, third-party sharing. A blanket "I agree" is not valid consent under GDPR.
- **Opt-in, unbundled, no pre-ticked boxes**, plain language, no service denial for refusing non-essential purposes.
- **Versioned immutable record:** who, purpose, timestamp, method, policy version, granted/withdrawn — append-only.
- **Withdrawal as easy as granting**, and it must propagate: revoke downstream processor access, halt processing, trigger deletion where retention law does not override.
- **Technically enforced**, not merely recorded: a policy engine gates every PHI read against live consent state. A consent record no API checks is theatre.
- **Minors / incapacity:** guardian consent, re-consent at majority, proxy rules.

- **Break-glass emergency access:** permitted, but logged loudly, alerted, reviewed after.

Retention

Never indefinite. Retention = statutory minimum $\cap$ purpose necessity, per data class.

Data	Typical rule
Clinical record	Statute-driven — India Clinical Establishments Act ~3 yrs; US state laws often 6–10 yrs; minors: until majority + N
HIPAA compliance documentation	6 years
Billing / tax	Per finance law (India ~8 yrs)
Auth / security logs	6–12 months
App telemetry, crash logs	30–90 days
Marketing consent	Until withdrawal
Backups	Same clock as primary, expiry enforced

Enforce with automated deletion jobs, not policy documents. Where backups cannot be surgically edited, use **crypto-shredding** — destroy the per-record key and the ciphertext becomes noise. Long-term research uses **anonymized** data (k-anonymity, differential privacy); pseudonymized data is still personal data.

Privacy-by-design measures

1. **Data minimization** — no full address for a teleconsult. Every field justifies itself.
2. **Privacy-protective defaults** — sharing off, analytics opt-in, “reject all” default.
3. **Purpose limitation** enforced at the API/policy layer.
4. **Pseudonymization by default**; re-identification requires a separately authorized join.
5. **End-to-end encryption** for patient $\leftrightarrow$ doctor chat and record transfer.
6. **On-device / edge processing** where possible — data never leaves the phone.
7. **Least privilege** — RBAC + ABAC, HIPAA minimum-necessary, access time-bound to an active care relationship.
8. **Immutable access audit trail surfaced to the patient** — they see who opened the record.
9. **DPIA/PIA before launch and before every PHI-touching feature.**
10. **Privacy dashboard** — access log, data export (portability), consent withdrawal, self-serve account deletion.
11. **No PHI in URLs, logs, analytics SDKs, or crash reports**; screenshot blocking; redacted notifications.

12. **Federated / SMPC analytics** — for cross-hospital statistics use secure sum: each site splits its value into random shares, distributes all but its own, and only the aggregate is ever revealed. No individual site's count leaks.
13. **Vendor controls** — DPAs, sub-processor register, third-party pen tests, no PHI to ad SDKs.
14. **Breach pipeline** — detection, 72-hour regulator notification (GDPR), patient notice.

Thesis line: security asks “can an attacker get in?”; privacy asks “should this data exist at all, for this purpose, for this long?” Encryption without key separation, and consent without technical enforcement, both fail the second question while passing the first.

Appendix: secure sum worked example (from the notes)

Three institutions computing a joint count of suspicious events without revealing their own.

Party	Value	Shares sent	Own share
TCS	30	$r_{AB}=12 \rightarrow$ Infosys, $r_{AC}=7$ $\rightarrow$ Wipro	$r_{AA} = 30-12-7$ $= 11$
Infosys	50	$r_{BA}=20 \rightarrow$ TCS, $r_{BC}=15 \rightarrow$ Wipro	$r_{BB} =$ $50-20-15 = 15$
Wipro	20	$r_{CA}=8 \rightarrow$ TCS, $r_{CB}=5 \rightarrow$ Infosys	$r_{CC} = 20-8-5$ $= 7$

Local sums: TCS $20+8+11 = 39$; Infosys $12+5+15 = 32$; Wipro $7+15+7 = 29$. Broadcast and add: $39 + 32 + 29 = 100$ suspicious events.

Each party's own value stays hidden because every share it released is masked by randomness it chose; only the total survives. Correctness holds because the random masks cancel — every r_{XY} is added exactly once across the local sums. Caveat: with only 3 parties, any 2 colluding can recover the third's value, so real deployments need more participants or an honest-majority assumption.